

Gestión de accesos y roles — CertManager

1. Modelo de roles

Rol	Alcance	Capacidades
Owner global (is_owner)	Toda la organización	Ve y gestiona todo: grupos, usuarios, configuración, certificados.
ADMIN de grupo	Su(s) grupo(s)	+ plantillas, miembros, alertas compartidas del grupo.
CONTRIBUTOR	Su(s) grupo(s)	+ crear/editar/borrar certificados del grupo.
VIEWER	Su(s) grupo(s)	Ver certificados + generar/recibir reportes.
Superusuario Django	/admin técnico	Solo la cuenta <code>createsuperuser</code> ; los Owner/Admin de la app NO acceden al admin de Django.

La autorización se aplica en servidor: `for_user` recorta los querysets por pertenencia a grupo; un middleware restringe `/admin` al superusuario real.

2. Autenticación

- **Local:** email + contraseña (hash PBKDF2 de Django).
- **LDAP/Active Directory:** verificación transparente (el mismo login prueba BD y luego el directorio si está habilitado en el panel LDAP).
- **2FA TOTP:** opcional por usuario; **exigible** por la organización.
- **API:** API key (`Authorization: Api-Key ...` o `X-API-Key`); solo se guarda el hash.

3. Políticas (configurables en Configuración → Seguridad)

Política	Control
Longitud mínima de contraseña	8 / 12 / 16 (aplicada por validador)
Expiración de contraseña	Off por defecto; cada mes/3/6 meses/año
Timeout de sesión por inactividad	0 = sin límite; N minutos
2FA exigido	Por organización
Bloqueo por fuerza bruta	N intentos por (IP, correo) → bloqueo temporal

4. Altas / bajas / cambios (procedimiento)

Acción	Cómo
Alta de usuario	Owner → Usuarios → invitar/crear (define rol por grupo).
Baja / desactivar	Owner → Usuarios → desactivar (no se borra; conserva auditoría).
Cambio de rol	Owner/Admin → detalle de grupo → membresías.
Reset de contraseña	<code>python manage.py changepassword <email></code> o el usuario desde su perfil.
Revocar API key	Owner → <code>/settings/api/</code> → revocar.

5. Matriz RACI (entrega y operación)

Actividad	Proveedor (dev)	Owner (Claro)	Plataforma/Infra (Claro)	Seguridad (Claro)
Código y correcciones	R/A	C	I	C
Despliegue inicial	R	A	R	C
Provisión MySQL/cert/firewall	I	A	R	C
Configuración funcional (paneles)	C	R/A	I	I
Gestión de usuarios/roles	I	R/A	I	C
RespalDOS	I	A	R	I
Monitoreo/operación	I	A	R	I
Pentest / cumplimiento	I	A	C	R

R=Responsable · A=Aprueba · C=Consultado · I=Informado.